

Corporate Compliance Policy

Sample document for SmartPolicy AI - Compliance knowledge base

1. Purpose

This policy defines the minimum compliance expectations for employees, contractors, and temporary staff. It is designed to help employees make responsible decisions, protect company information, avoid conflicts of interest, and report concerns without fear of retaliation.

2. Scope

This policy applies to all business functions, locations, remote work settings, third-party interactions, customer engagements, and any activity performed on behalf of the company.

3. Core Compliance Principles

- Act honestly, fairly, and transparently in all business dealings.
- Follow applicable laws, contractual obligations, internal policies, and customer requirements.
- Protect confidential, personal, financial, and customer information.
- Avoid conflicts of interest and disclose potential conflicts promptly.
- Report suspected misconduct, policy breaches, security incidents, or unethical behavior immediately.

4. Roles and Responsibilities

Role	Responsibilities
All Employees	Follow this policy, complete assigned training, protect information, and report concerns promptly.
Managers	Set the right example, guide teams, review escalations, and ensure corrective actions are completed.
Compliance Team	Maintain policies, review reported concerns, support investigations, and provide compliance guidance.
IT and Security Teams	Support data protection, access control, incident response, system monitoring, and evidence preservation.

5. General Conduct Standard

Employees must not engage in fraud, harassment, discrimination, falsification of records, misuse of company assets, unauthorized disclosure of information, or any conduct that may damage customer trust or company reputation.

Data Privacy and Information Protection

6. Confidential Information

Confidential information includes customer data, employee data, financial information, contracts, pricing, product plans, internal reports, credentials, technical documentation, and any information marked or reasonably understood as confidential.

Employees must:

- Access confidential information only when needed for an approved business purpose.
- Share confidential information only with authorized persons.
- Use approved company systems for storage, transfer, and collaboration.
- Avoid copying policy documents, reports, customer files, or credentials to personal email, personal cloud drives, or unapproved messaging tools.

7. Personal Data Handling

Personal data must be collected, used, stored, and deleted only for legitimate business purposes. Employees must avoid collecting unnecessary data and must not process personal data beyond the approved purpose.

Personal data examples include employee ID, address, phone number, bank details, government ID, health-related information, customer records, login identifiers, and any information that can identify a person.

8. Data Sharing with External Parties

Employees must not share confidential or personal data with vendors, consultants, customers, auditors, or other external parties unless the sharing is approved, documented, and covered by appropriate contractual or security controls.

Before sharing data externally, employees must confirm:

- The business purpose is valid and approved by the manager or process owner.
- The recipient is authorized to receive the data.
- Only the minimum required information is shared.
- The transfer method is secure and approved by IT or Security.
- Any required non-disclosure agreement, data processing agreement, or customer approval is in place.

9. Data Retention and Disposal

Records must be retained according to legal, contractual, tax, audit, and business requirements. Employees must not delete records that are part of an investigation, audit, dispute, or legal hold. Outdated records must be disposed of securely using approved methods.

10. Remote Work and Device Security

When working remotely, employees must use secure networks, keep devices locked when unattended, avoid public screen exposure, and report lost or stolen devices immediately. Company information must not be downloaded to personal devices unless specifically approved.

Incident Reporting and Security Compliance

11. Reportable Incidents

An incident is any event that may compromise company information, customer trust, legal obligations, financial accuracy, workplace safety, or ethical standards. Employees must report incidents even when the full impact is not yet known.

Reportable examples include:

- Email sent to the wrong recipient containing confidential or personal data.
- Loss or theft of a laptop, phone, ID card, access token, or storage device.
- Suspicious email, phishing attempt, malware alert, or unauthorized login attempt.
- Unauthorized access to employee, customer, finance, or compliance records.
- Suspected bribery, fraud, falsification of records, policy violation, or retaliation.

12. Incident Reporting Timeline

Employees must report suspected data breaches, privacy incidents, compliance violations, or security concerns immediately and preferably within 24 hours of discovery. Urgent issues must be escalated through the fastest available approved channel.

13. What Employees Must Do During an Incident

- Stop any further unauthorized sharing or processing if safe to do so.
- Inform the manager, Compliance Team, or IT Security Team as applicable.
- Preserve evidence such as email headers, screenshots, timestamps, ticket numbers, filenames, and recipient details.
- Do not delete emails, files, logs, or chat messages related to the incident.
- Do not contact external parties about the incident unless instructed by Compliance, Legal, or authorized management.

14. Investigation Support

Employees are expected to cooperate with investigations, provide truthful information, protect confidentiality, and avoid discussing investigation details with unauthorized persons. Retaliation against anyone who raises a concern in good faith is prohibited.

15. Access Control Requirements

Access to systems, folders, applications, and reports must be based on role need. Shared passwords are not allowed. Access must be reviewed periodically and removed when employees change roles, transfer teams, or leave the company.

16. Training and Awareness

Employees must complete mandatory compliance, information security, data privacy, and code of conduct training within the assigned deadline. Managers must follow up on overdue training and reinforce policy expectations during team discussions.

Ethics, Conflicts, Gifts, and Enforcement

17. Anti-Bribery and Gifts

Employees must not offer, promise, request, accept, or authorize bribes, kickbacks, facilitation payments, or improper advantages. Gifts, hospitality, sponsorships, and entertainment must be modest, infrequent, transparent, and compliant with company limits and customer rules.

Gifts or hospitality must not be accepted when they may influence business decisions, create a conflict of interest, or appear improper. Cash, cash equivalents, personal loans, and expensive personal benefits are prohibited.

18. Conflict of Interest

A conflict of interest may arise when personal interests, family relationships, outside employment, investments, vendor relationships, or personal benefits interfere with company duties. Employees must disclose actual or potential conflicts to their manager or Compliance Team.

Examples of potential conflicts:

- A family member works for a vendor being evaluated by the employee.
- An employee has a financial interest in a supplier, customer, or competitor.
- An employee performs outside work that affects company time, judgement, or confidentiality.
- An employee receives personal benefits from a business partner.

19. Accurate Records

Business records, expense claims, attendance logs, invoices, approvals, audit evidence, project reports, and customer documentation must be accurate, complete, timely, and supported by proper evidence. Falsification or concealment of records is a serious violation.

20. Reporting Channels

Employees may report concerns through their manager, HR, Compliance, Legal, IT Security, or the designated ethics reporting channel. Concerns can be raised in good faith even when the employee is unsure whether a violation has occurred.

21. Non-Retaliation

The company prohibits retaliation against anyone who reports a concern in good faith, participates in an investigation, or refuses to participate in improper conduct. Retaliation should be reported immediately.

22. Consequences of Non-Compliance

Policy violations may result in coaching, retraining, access restriction, disciplinary action, termination, contract termination, legal action, or reporting to authorities, depending on severity and applicable requirements.

Acknowledgement

By following this policy, employees help protect customers, colleagues, business partners, company assets, and the reputation of the organization.